

Лабораторна робота №2

Тема: Практичне впровадження систем якості та безпеки

Мета роботи

- Навчитися інтегрувати цикл **PDCA** у реальний Pipeline розробки.
- Провести **Mini-Audit** системи на відповідність вимогам безпеки.
- Розробити план реагування на інциденти згідно з тріадою **CIA**.

Вихідні дані

Виберіть один із "критичних" проектів для симуляції:

1. **BioTech-система:** Хмарне сховище результатів ДНК-тестів.
2. **AutoPilot Module:** ПЗ для керування міським дроном-кур'єром.
3. **Smart-Gov:** Система електронного голосування на базі блокчейн.

Завдання 1. Оптимізація процесу за ISO 9001 (PDCA Workshop)

Уявіть, що у вашому проекті виникла проблема: **"Кожен третій реліз містить критичний баг, який завалює продуктивне середовище"**.

Вам потрібно застосувати цикл **PDCA** для виправлення цього процесу. Заповніть форму:

1. **Plan (Проектування змін):** Виберіть один конкретний інструмент (напр. *SonarQube, Unit Testing 80% coverage, Mandatory Code Review*). Опишіть, як ви його впровадите.
2. **Do (Впровадження):** Опишіть крок за кроком, як змінюється Git Flow команди після введення нового правила.
3. **Check (Контроль метрик):** Які показники в Jira або GitHub Actions ви будете моніторити протягом місяця, щоб зрозуміти, чи спрацював план?
4. **Act (Коригування):** Що ви зробите, якщо через 2 тижні виявиться, що швидкість розробки впала вдвічі, а якість не зросла?

Завдання 2. Практичний аудит безпеки за Тріадою CIA

Для вашого проекту проведіть симуляцію трьох негативних сценаріїв. Для кожного запропонуйте **технічне рішення**.

Сценарій (Що сталося?)	Параметр (С, І чи А)	Технічне рішення (Як запобігти автоматично?)
Адміністратор БД випадково видалив таблицю з логами	Availability	Приклад: Впровадження Point-in-Time Recovery (PITR) на AWS RDS
Зловмисник підмінив номер гаманця в API-запиті	Integrity	
Стажер виклав приватний ключ від сервера у публічний GitHub	Confidentiality	

Завдання 3. Проектування "Control List" (Annex A ISO 27001)

Оберіть один із компонентів вашої системи (наприклад, **Модуль авторизації**) та розробіть для нього 3 технічні контроли.

- **Контроль доступу:** Опишіть конфігурацію політики паролів або використання MFA (напр. інтеграція з Google Authenticator).
- **Шифрування:** Вкажіть, який алгоритм (напр. AES-256) використовується для бази даних та який протокол (напр. TLS 1.3) для трафіку.
- **Логування:** Напишіть приклад структури логу (JSON), який фіксує підозрілу активність (хто, коли, з якої IP, що намагався зробити).

Завдання 4. Симуляція процедури сертифікаційного аудиту

Ви — внутрішній аудитор. Вам потрібно перевірити процес верифікації коду за стандартом **IEEE 1012**.

1. Створіть **Checklist** з 5 питань для перевірки розробників (напр. "Чи проходить код автоматичну перевірку на вразливості перед Merge?").
2. Опишіть, які **докази** (artifacts) ви вимагатимете від команди (напр. скріншоти з CI/CD, звіти з penetration test).